

What is a Password Attack?

A **password attack** is a method used by attackers to gain unauthorized access to a system by cracking or guessing a user's password. Passwords remain one of the most common security mechanisms, making them a frequent target.

Goals of Password Attacks

- Gain **unauthorized access**
- **Escalate privileges** on a system
- Move **laterally** in a network
- Exfiltrate **sensitive data**
- Crack passwords from **hash dumps**

Common Types of Password Attacks

Attack Type	Description
Brute Force Attack	Tries all possible combinations until the correct one is found. Very slow but guaranteed.
Dictionary Attack	Uses a predefined list of commonly used passwords. Faster than brute force.
Hybrid Attack	Combines dictionary + brute force (e.g., adding numbers/symbols to words).
Credential Stuffing	Uses leaked credentials from other sites to log into target systems.
Phishing Attack	Tricks the user into revealing their password via fake websites or emails.
Social Engineering	Gathers information about the user to guess the password (e.g., birthdate, pet name).
Keylogging	Captures keystrokes to steal passwords in real time.
Shoulder Surfing	Observing someone typing their password physically.
Rainbow Table Attack	Uses precomputed hash-password mappings to crack password hashes quickly.
Pass-the-Hash	Uses hashed passwords to authenticate without knowing the actual password.
Man-in-the-Middle	Captures credentials during transmission using tools like Wireshark or Ettercap.

Password Storage Mechanisms

- Passwords are not stored in plain text.
- Systems store **hashed passwords** (MD5, SHA1, bcrypt, etc.).
- In Windows: C:\Windows\System32\config\SAM
- In Linux: /etc/shadow

Popular Tools Used for Password Attacks

Tool	Use Case
John the Ripper	Offline hash cracking (Unix, Windows, archive formats)
Hydra	Online login brute-force (SSH, FTP, HTTP, etc.)
Medusa	Fast parallel brute-force tool
Ncrack	Network login testing tool (SSH, RDP, etc.)
Hashcat	GPU-based fast hash cracking
Mimikatz	Dumps credentials from Windows memory
Burp Suite	Web login brute-force testing

Defense Against Password Attacks

Defense Mechanism	Description
Strong Password Policy	Enforce length, complexity, and expiration
Account Lockout	Lock accounts after failed login attempts
Two-Factor Authentication (2FA)	Adds a second layer of verification
Salting Passwords	Adds randomness to passwords before hashing
Secure Transmission (HTTPS, SSH)	Prevents interception in transit
Monitor Login Attempts	Use SIEM tools to detect brute-force attempts
Password Managers	Generate and store strong passwords

Brute Force vs Dictionary vs Hybrid

Feature	Brute Force	Dictionary	Hybrid
Speed	Slow	Fast	Medium
Accuracy	Guaranteed	Depends	Good
Resource Usage	High	Low	Medium
Best For	Short/simple passwords	Common passwords	Modified common passwords

Real-World Example

Brute-force SSH login using Hydra:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.10
```

Crack a hash using John the Ripper:

```
john --wordlist=rockyou.txt --format=raw-md5 hash.txt
```

Best Practices for Password Security

- Use **12+ character passwords** with symbols and mixed case
- Don't reuse passwords across sites
- Avoid dictionary words and personal info
- Use **password managers** like Bitwarden or KeePass
- Enable **2FA/MFA** everywhere possible

Summary Table

Term	Description
Brute Force	Tries all combinations
Dictionary	Wordlist-based guessing
Hybrid	Wordlist + rules
Rainbow Table	Precomputed hash-password mappings
Credential Stuffing	Using leaked passwords on other sites
Pass-the-Hash	Uses the hash directly for authentication